

BEFORE Placeholder

AFTER

Third-Party Security Program Charter (Internal)

Document classification: Internal Document owner: Head of IT Security & Network Management (or delegate) Version: 0.1 Effective date: _____ Review cadence: Every 12 months or upon material change

1. Purpose

This charter establishes the Third-Party Security Program to ensure that third parties (suppliers, vendors, outsourcers, and sub-processors) are assessed, onboarded, and monitored in a manner that protects confidentiality, integrity, and availability of the organisation's services and data, and supports compliance with applicable regulatory and privacy obligations.

2. Objectives

The program objectives are to:

- Ensure third-party services are integrated securely using standard, engineering-led patterns.
- Apply proportionate security controls based on supplier criticality and exposure.
- Identify and remediate third-party security risks prior to contract execution and onboarding.
- Maintain ongoing assurance through monitoring, periodic review, and trigger-based reassessment.
- Manage exceptions through explicit approval, compensating controls, and time-bound remediation.

3. Scope

3.1 In scope

- All third parties providing technology services, outsourced operations, managed services, SaaS, hosting, software, and any service that:
 - Processes/stores/transmits organisational data, or
 - Requires connectivity/integration into organisational systems, or
 - Has privileged access, or
 - Supports business-critical services.

3.2 Out of scope

- Non-technology suppliers with no data processing and no system access (unless risk triggers apply).
- One-off purchases with no ongoing service component (unless they involve data or privileged access).

4. Definitions

- **Third party / Supplier:** External entity providing a service or product.
- **Sub-processor / Fourth party:** External entity used by the supplier to deliver the service.
- **Tiering:** Classification of suppliers as Critical / Important / Low based on impact and exposure.
- **Exception:** A formally approved deviation from minimum security requirements with compensating controls and an expiry date.

5. Tiering model

Suppliers are classified using the approved **Supplier Tiering Decision Tree** (see ``tiering-model1/``), resulting in one of:

- **Critical (Tier 1):** Business critical, privileged access/production influence, sensitive data at scale, or elevated connectivity/fourth-party risk.
- **Important (Tier 2):** Meaningful integration and/or limited sensitive data, without Tier 1 triggers.
- **Low (Tier 3):** Low sensitivity, minimal/no integration, low business impact.

Default rule: when uncertain, classify to the higher tier.

6. Minimum security requirements (baseline)

Minimum requirements are defined by tier and maintained in:

- ``program-charter/03-minimum-security-requirements-by-tier.md`` and implemented using:
- control baselines (``control-baselines/``)
- evidence packs (``evidence-packs/``)
- integration patterns (``integration-patterns/``)

For **Critical** suppliers, minimum requirements will prioritise:

- Strong identity controls (SSO/MFA, least privilege, privileged access controls)
- Logging/auditability for administrative and access events
- Secure connectivity patterns and segmentation where applicable
- Vulnerability management and timely remediation
- Incident notification commitments and tested response
- Resilience and recovery expectations proportionate to criticality

7. Supplier lifecycle (high level)

The program applies the following lifecycle:

1. **Intake & tiering** (business owner + security review)
2. **Due diligence** (evidence pack issued; gaps captured)
3. **Contracting** (security schedule / DPA / right-to-audit positions)
4. **Onboarding** (secure integration pattern selected; controls validated)
5. **Ongoing monitoring** (trigger events + periodic review by tier)
6. **Offboarding** (access removal, data return/destruction, attestations)

8. Roles and responsibilities (summary)

- **Business owner:** accountable for supplier selection, scope, and acceptance of residual risk.
- **Security (engineering/architecture):** defines baselines, reviews evidence, approves integration patterns, validates controls.
- **Procurement:** ensures process adherence, manages commercial negotiation and renewals.
- **Legal/Privacy:** reviews contractual and data protection obligations.
- **IT/Platform teams:** implement technical integration controls and operational handover.

A detailed RACI is maintained in ``program-charter/05-roles-and-responsibilities-raci.md`` (or ``operating-model/``).

9. Governance, approvals, and escalation

Governance requirements, approval thresholds by tier, and escalation paths are defined in:

- ``program-charter/02-governance-approvals-escalation.md``

10. Exceptions

Exceptions to minimum requirements must:

- Be documented with the control gap, compensating controls, and an expiry date
- Be approved by the defined authority for the relevant tier
- Be tracked to closure with a remediation plan and target timeline

The exception standard and template are maintained in:

- ``program-charter/04-policy-exceptions-standard.md``

11. Metrics and reporting

KPIs/KRIs are defined to measure adoption and risk posture (e.g., critical suppliers assessed, overdue remediation actions, exception volumes/age). Metrics definitions are maintained in:

- ``metrics/`` and referenced in ``program-charter/06-kpis-kris.md``

12. Review and maintenance

This charter is reviewed at least annually and upon material changes to:

- regulatory expectations
- organisational risk appetite
- architecture/integration patterns
- supplier risk profile or outsourcing strategy